A Dragonfly Aims to Fix Wi-Fi's Wings

Liran Ma, Zhipeng Cai, and Wei Cheng

Copyright © 2019 Liran Ma, Texas Christian University; Zhipeng Cai, Georgia State University; Wei Cheng, University of Washington Tacoma

The development of this document is partially funded by the National Science Foundation's CyberTraining program under award No. OAC-1829553. Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.2 or any later version published by the Free Software Foundation. A copy of the license can be found at `http://www.gnu.org/licenses/fdl.html`.

Introduction: In January 2018, WPA3 is announced to be a replacement to WPA2. The WPA3 standard replaces the pre-shared key (PSK) exchange with Simultaneous Authentication of Equals (SAE) as defined in IEEE 802.11-2016 resulting in a more secure initial key exchange in personal mode. It is also claimed that WPA3 will mitigate security issues posed by weak passwords and simplify the process of setting up devices with no display interface. However, just one year since the launch of WPA3 and researchers have unveiled several serious vulnerabilities in the wireless security protocol that could allow attackers to recover the password of the Wi-Fi network.

Contents

1 Lab Prep **1**

2 SAE Explained **4**

3 SAE Observation **6**

4 General Questions **9**

1 Lab Prep

1.1 Introduction to WPA3 and Simultaneous Authentication of Equals

WPA3 is the next generation of Wi-Fi security and provides cutting-edge security protocols to the market. Building on the widespread success and adoption of WPA2, WPA3 adds new features to simplify Wi-Fi security, enable more robust authentication, deliver increased cryptographic strength for highly sensitive data markets, and maintain resiliency of mission critical networks.

WPA3-personal brings better protections to individual users by providing more robust password-based authentication, even when users choose passwords that fall short of typical complexity recommendations (i.e., allows natural password selection; Users can choose passwords that are easier to remember). This capability is enabled through Simultaneous Authentication of Equals (SAE), which replaces Pre-shared Key (PSK) in WPA2-Personal. The technology is resistant to offline dictionary attacks where an adversary attempts to determine a network password by trying possible passwords without further network interaction. In addition, it delivers enhanced protections with no change to the way users connect to a network.

In the following subsections, we will install WPA3 related packages on a router and configure a WPA3-enforced wireless network.

1.2 Install wpad-openssl

We start by installing WPA3 related packages as the default wpad-basic/wpad-mini package does not support it. We will need to remove wpad-mini first and then install the full version of wpad-openssl. **Your router needs to have Internet to install the software package.**

Log onto the router as the root user via ssh, and issue the following commands:

```
opkg update

opkg remove wpad-basic
# Or opkg remove wpad-mini (if appropriate)
```

An exmmple screenshot is shown in Fig. 1.

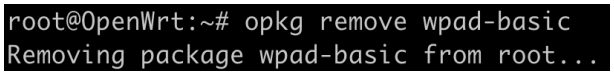


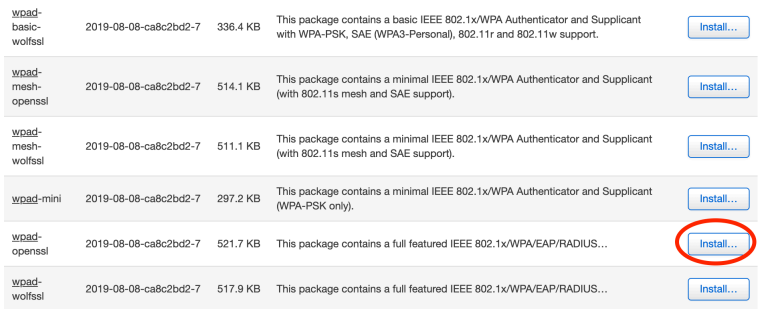
Figure 1: Remove wpad-basic.

Next, install wpad-openssl as follows.

```
opkg install wpad-openssl
```

It should be okay the opkg update command gives some warnings message. However, the installation of wpad-openssl needs to be successful. Reboot your router to make the newly installed software effective.

If you have difficulties using the command line to install wpad-openssl, you can use the web interface to install it. Go to System -> Software and search for wpad after updating the list first. Then, select wpad-openssl to install (an example is shown in Fig. 2).



wpad-basic-wolfssl	2019-08-08-ca8c2bd2-7	336.4 KB	This package contains a basic IEEE 802.1x/WPA Authenticator and Supplicant with WPA-PSK, SAE (WPA3-Personal), 802.11r and 802.11w support.	Install...
wpad-mesh-openssl	2019-08-08-ca8c2bd2-7	514.1 KB	This package contains a minimal IEEE 802.1x/WPA Authenticator and Supplicant (with 802.11s mesh and SAE support).	Install...
wpad-mesh-wolfssl	2019-08-08-ca8c2bd2-7	511.1 KB	This package contains a minimal IEEE 802.1x/WPA Authenticator and Supplicant (with 802.11s mesh and SAE support).	Install...
wpad-mini	2019-08-08-ca8c2bd2-7	297.2 KB	This package contains a minimal IEEE 802.1x/WPA Authenticator and Supplicant (WPA-PSK only).	Install...
wpad-openssl	2019-08-08-ca8c2bd2-7	521.7 KB	This package contains a full featured IEEE 802.1x/WPA/EAP/RADIUS...	Install...
wpad-wolfssl	2019-08-08-ca8c2bd2-7	517.9 KB	This package contains a full featured IEEE 802.1x/WPA/EAP/RADIUS...	Install...

Figure 2: Install wpad-openssl via web GUI.

1.3 Configure a WPA3 Network with SAE

Next, we proceed to configure a WPA3 SAE enforced wireless network. Select an SSID (i.e., the network name) and a secret for your wireless network. Issue a set of uci commands according the following prototypes (fill in the values based on your actual situation) to enable SAE.

```
uci set wireless.default_radio1.mode='AP'
uci set wireless.default_radio1.ssid='SSID-of-your-choice'
uci set wireless.default_radio1.encryption='sae'
uci set wireless.default_radio1.key='secret-of-your-choice'
uci commit wireless && wifi
```

An example command sequence is shown in Fig. 3. You can verify the configurations via the uci command with the show option (i.e., uci show wireless).

```
uci set wireless.default_radio1.mode='ap'
uci set wireless.default_radio1.ssid='Eureka-WPA3'
uci set wireless.default_radio1.encryption='sae'
uci set wireless.default_radio1.key='eureka-labs'
```

Figure 3: Enable WPA3 SAE via command line.

If you have difficulties using the command line to configure WPA3 with SAE, you can use the web interface to configure it. Go to Network -> Wireless, and select an wireless interface to configure. Under Wireless Security, choose WPA3-SAE (an example is shown in Fig. 4).

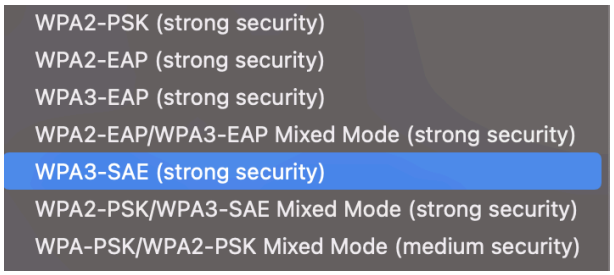


Figure 4: Enable WPA3 SAE via web GUI.

2 SAE Explained

SAE is a new method of authenticating a device trying to connect to a wireless network. It is a variation of the so-called dragonfly handshake that uses cryptography to prevent an eavesdropper guessing a password. As the name suggests, SAE works by considering devices as equals, rather than treating one side as an explicit requester and the other side an authenticator (traditionally the connecting device and the router, respectively). Either party can initiate the handshake, and then they proceed through sending their authentication information independently. The overall SAE association and authentication procedure is illustrated in Fig. 5.

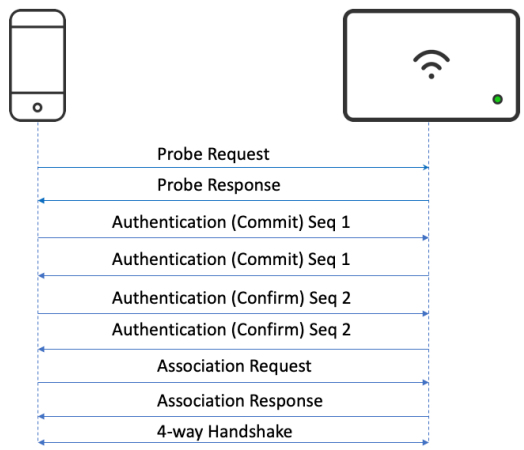


Figure 5: SAE flowchart (sequence of frame exchange).

When a client connects to an access point (AP), they go into phases of commit and then confirm. Once there is a commitment, the client and AP can then go into the confirm states each time there is a session key to be generated.

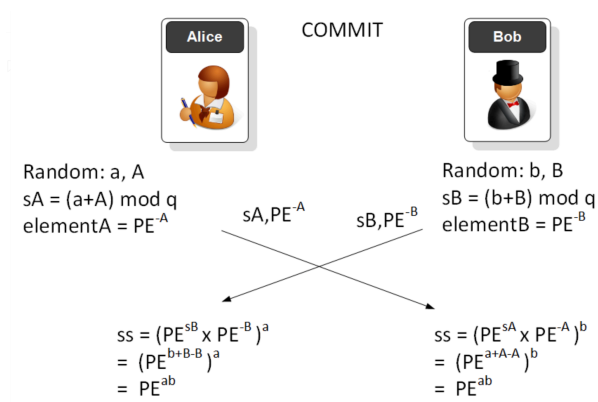


Figure 6: Dragonfly commit phase.

In the commit phase (as it is depicted in Fig. 6), Alice (the client) generates two random values

(a, A), then computes a scalar value ($a + A$). The value that Alice will pass is the PE (Password Equivalent, such as hashed value of the password that Bob and Alice know) raised to the power of $-A$. The operations are done with (mod q) and where q is a large prime number. Bob does the same, and then they exchange values. In the end they will have the same shared commit key (PE^{ab}). The password has been used to validate Bob and Alice, and they will only have the shared shared commit value if they both have the same password. The intruder cannot determine either the original password or the final shared value. Thw whole process uses Diffie-Hellman key exchange method with an added an authentication element.

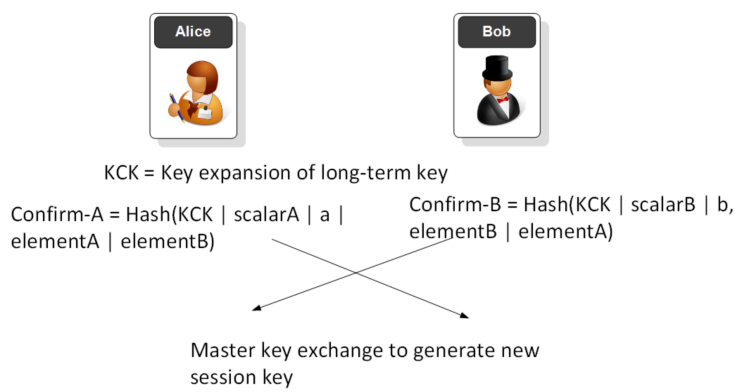


Figure 7: Dragonfly confirm phase.

In the confirm phase we then use the long-term key to generate a unique and cryptographically strong session key (as shown shown in Fig. 7). An attacker cannot determine the password used or the long-term master key (PMK). The cracking of one session key will not reveal the rest of the keys which have been used, which is not the case for WPA-2.

Download a Python script from `http://csfaculty.tcu.edu/ma/eureka/?dir=WPA3-SAE`.

2.0.1 Calculate an example of all relevant parameters in the SAE key exchange process using the downloaded Python script.

2.0.2 Explain how does SAE work based on your calculation.

An intruder should not be able to connect to a network unless they known password that the AP uses. Also, an intruder should not be able to guess either the password or the long-term authentication element of the password.

2.0.3 Explain why does SAE forward secrecy?

3 SAE Observation

Have a WPA3 ready device connect to your wireless network (note that not all devices support WPA3 yet). You should use the secret that you have selected in Section 1.3 when connecting to the network. At the same time, start a Wireshark capture on the right channel to capture the SAE authentication and key exchange frames.

3.1 SAE Authentication

First, we will observe the commit and confirm phases in the SAE authentication process. Open the frame capture file in Wireshark, and locate the series of SAE exchange frames. An example is shown in Fig. 8. The sequence of frames starts with a beacon message and ends with the session key generation frames. A complete example of captured frames is available at `http://csfaculty.tcu.edu/ma/eureka/?dir=WPA3-SAE`.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000…	BelkinIn_db:…	Broadcast	802.11	217	Beacon frame, SN=123, FN=0, Flags=.....C, BI=100, SSID=Eureka-WPA3
2	0.003…	ee:f2:fc:38:…	BelkinIn_db:…	802.11	144	Probe Request, SN=2052, FN=0, Flags=.....C, SSID=Eureka-WPA3
3	0.004…	BelkinIn_db:…	ee:f2:fc:38:…	802.11	211	Probe Response, SN=73, FN=0, Flags=.....C, BI=100, SSID=Eureka-WPA3
4	0.025…	ee:f2:fc:38:…	BelkinIn_db:…	802.11	157	Authentication, SN=1, FN=0, Flags=.....C
5	0.076…	BelkinIn_db:…	ee:f2:fc:38:…	802.11	157	Authentication, SN=74, FN=0, Flags=.....C
6	0.079…	ee:f2:fc:38:…	BelkinIn_db:…	802.11	93	Authentication, SN=2, FN=0, Flags=.....C
7	0.080…	BelkinIn_db:…	ee:f2:fc:38:…	802.11	93	Authentication, SN=75, FN=0, Flags=.....C
8	0.083…	ee:f2:fc:38:…	BelkinIn_db:…	802.11	189	Association Request, SN=2053, FN=0, Flags=.....C, SSID=Eureka-WPA3
9	0.104…	BelkinIn_db:…	ee:f2:fc:38:…	802.11	169	Association Response, SN=76, FN=0, Flags=.....C
10	0.139…	BelkinIn_db:…	ee:f2:fc:38:…	EAPOL	184	Key (Message 1 of 4)
11	0.142…	ee:f2:fc:38:…	BelkinIn_db:…	EAPOL	190	Key (Message 2 of 4)
12	0.148…	BelkinIn_db:…	ee:f2:fc:38:…	EAPOL	250	Key (Message 3 of 4)
13	0.150…	ee:f2:fc:38:…	BelkinIn_db:…	EAPOL	162	Key (Message 4 of 4)

Figure 8: SAE all captured frames (matching the flowchart).

3.1.1 Provide a screenshot of your captured SAE authentication frame sequence. It should match with the explanation presented in Section. 2 and Fig 8.

.

There are four frames in the SAE authentication process. Click on the first authentication frame, the detailed information of the commit message will be displayed. An example is shown in Fig. 9.

3.1.2 Provide screenshots of your captured authentication frames for SAE commit. Explain the information presented in the commit frames.

.

3.1.3 Optional. Calculate the shared secret using the Python script downloaded in Section. 2. Decrypt a wireless frame (e.g., a ping packet) with your calculated secret key.

3.1.4 Provide screenshots of your captured frames for SAE confirm. An example is shown in Fig. 10.

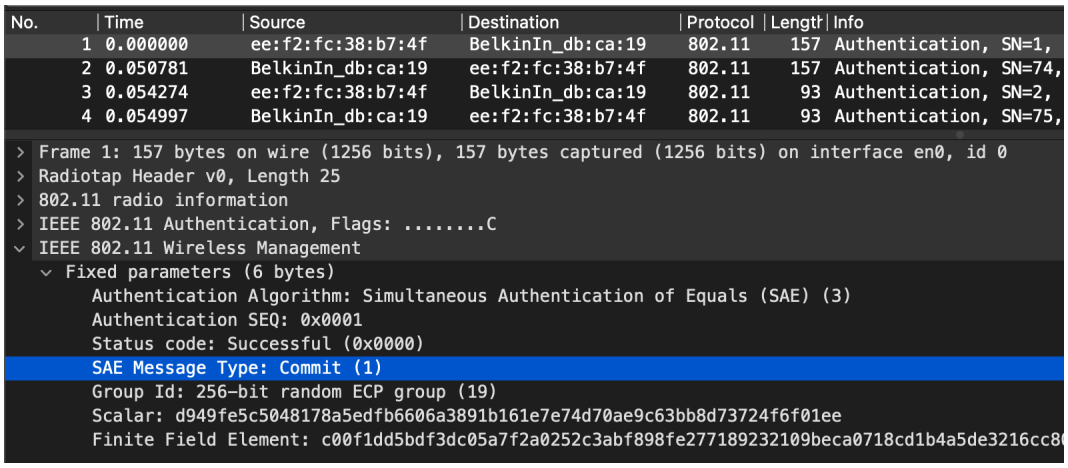


Figure 9: SAE authentication: commit phase.

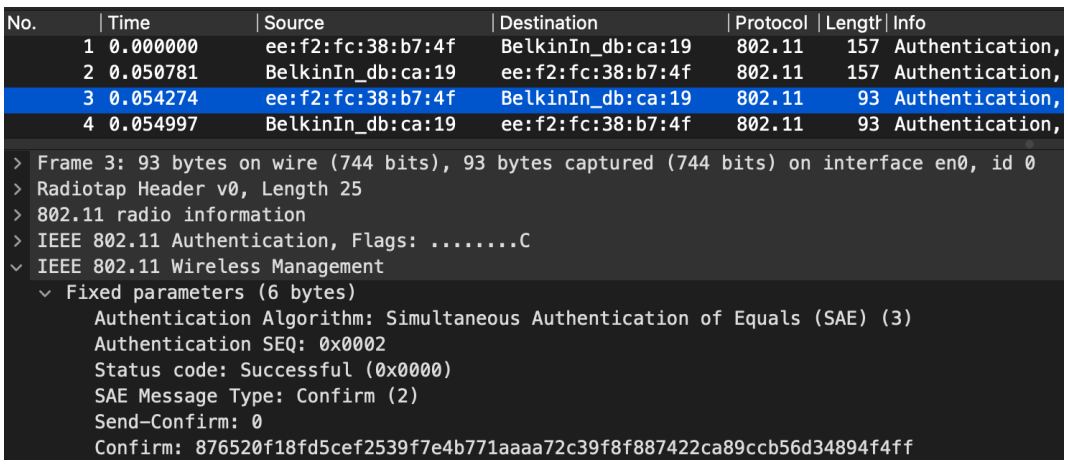


Figure 10: SAE authentication: confirm phase.

3.2 Session Key Generation

Once a shared secret is achieved, a session key will be generated via the 4-way handshake procedure. There will be four frames in the handshake procedure. The first handshake exchange frames are shown in Fig. 11.

3.2.1 Provide screenshots of your captured 4-way handshake frames.

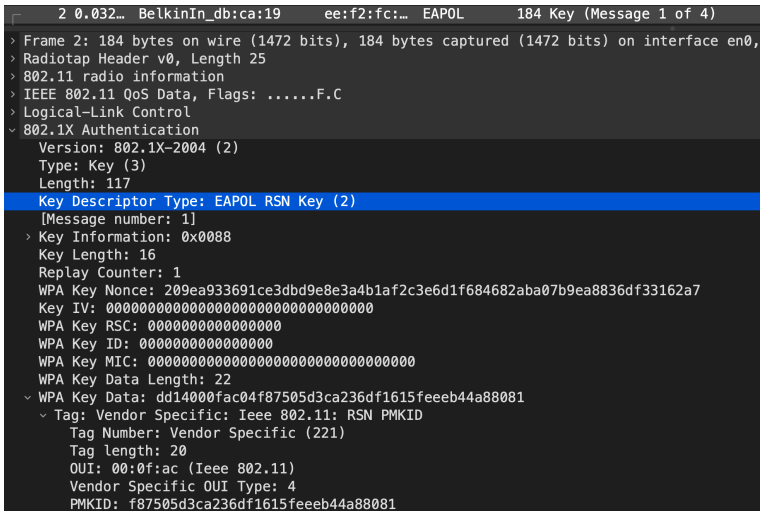


Figure 11: 4-Way handshake exchange message 1 of 4.

3.2.2 Reconnect your client to the network and check the SAE exchange messages. Explain why does SAE support the feature of forward secrecy that WPA2-PSK does not support? Suppose an attacker gains access to encrypted data that a router is sending and receiving from the wider Internet. Previously, the attacker could hold on to that data. Then later, if they succeeded in nabbing a password, they could decrypt the earlier stored data.

3.3 SAE Vulnerabilities

Though WPA3 relies on a more secure handshake, known as Dragonfly, that aims to protect Wi-Fi networks against offline dictionary attacks, security researchers Mathy Vanhoef and Eyal Ronen found weaknesses in the early implementation of WPA3-Personal, allowing an attacker to recover WiFi passwords by abusing timing or cache-based side-channel leaks (`https://wpa3.mathyvanhoef.com/`). In a research paper, dubbed DragonBlood, researchers detailed two types of design flaws in WPA3—first leads to downgrade attacks and second to side-channel leaks. The paper is available at `https://papers.mathyvanhoef.com/dragonblood.pdf`.

3.3.1 Explain how to exploit the discovered vulnerabilities to recover WiFi passwords. If possible, demonstrate it in a real experiment.

4 General Questions

4.0.1 What is the most challenging part in this lab?

4.0.2 Which part of this lab helps you better understand the concepts covered in the lecture?

4.0.3 Are the lab activities fun and inspiring learning?

4.0.4 Are there any corrections/improvements needed to apply to this lab?